Information Risk Management: GRC & COBIT

By **Kavinga Yapa Abeywardena**

Sri Lanka Institute of Information Technology (SLIIT)

Governance, Risk Management, Compliance (GRC)

- An ‘umbrella term’ that covers these three areas of enterprise activities (Not just IT)
- Constantly reviewed and analysed to enhance the organisations performances and efficient delivery of stakeholder needs.
- GRC activities are typically based on principles, policies, models, frameworks, organisational structures. Etc.

Governance, Risk Management, Compliance (GRC)

- **Governance**: Exercise of authority; control; government; arrangement.
- **Risk (management):** Hazard; danger; peril; exposure to loss, injury, or destruction (The act or art of managing; the manner of treating, directing, carrying on, or using, for a purpose; conduct; administration; guidance; control)
- **Compliance**: The act of complying; a yielding; as to a desire, demand, or proposal; concession; submission

Webster's Online Dictionary

Governance, Risk Management, Compliance (GRC)

Simpler Definitions

- **Governance**: Effective management of a company by executives & senior management
- **Risk (management):** Ability to effectively mitigate risks that deter company's success
- **Compliance**: Abiding by rules, regulations, laws and industrial ethics & standards

Governance, Risk Management, Compliance (GRC)

- Different types of GRC
  - Corporate GRC
  - Project GRC
  - Information Technology GRC
  - Environmental GRC
  - Economic and financial GRC

IT GRC

- **IT Governance:** Establishes decision structures and tracking mechanisms.
- **IT Risk Management:** Helps mitigate adverse effects and identifies opportunities.
- **IT Compliance:** Ensure that an organization is not only adhering to laws and regulations, but is also taking into account corporate responsibilities and industry standards.

What's New in IT GRC ?

- IT GRC initiatives have traditionally been scattered across organizations without any coordination or synchronization.
- Need a unified approach for better results and efficiency. 'Holistic Approach' is the buzz word used in the industry.
- High demand for products that help organizations effectively break down scattered initiatives & create a centralized approach to managing **RISK** and **COMPLIANCE** while simultaneously ensuring good **GOVERNANCE.**

COBIT for IT GRC

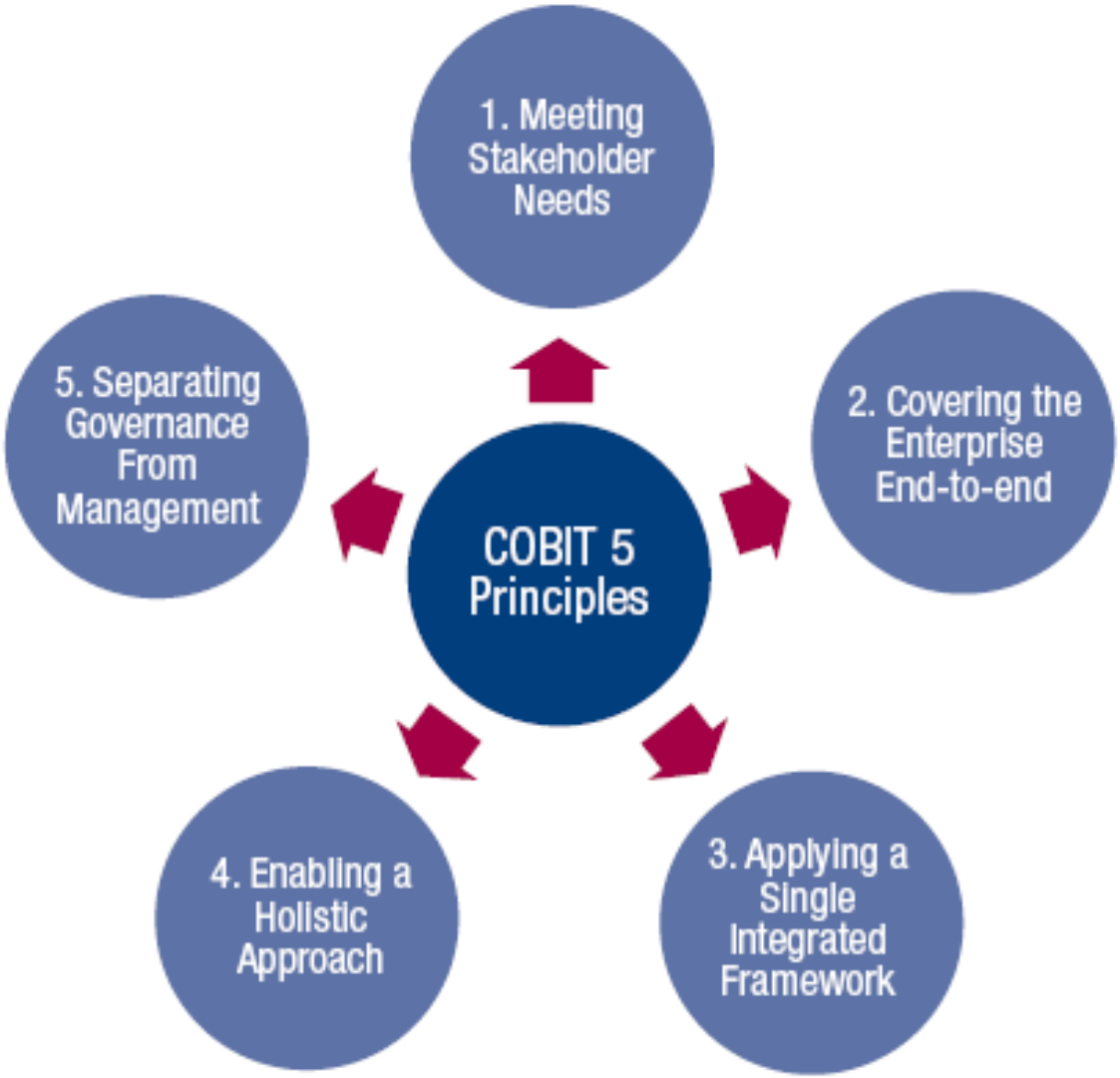
- COBIT is a framework that guides IT professionals and enterprise leaders to fulfill their IT governance responsibilities while delivering value to the business.
- Developed and maintained by ISACA (Information Systems Audit and Control Association), COBIT 5 is the latest version.



The COBIT 5 Framework

- Helps enterprises to create optimal value from IT by maintaining a **balance between realising benefits and optimising risk levels** and resource use.
- Enables **IT to be governed and managed in a holistic manner** for the entire enterprise, taking in the full end-to-end business and functional areas of responsibility, considering the IT-related interests of internal and external stakeholders.
- The COBIT 5 **principles** and **enablers** are generic and useful for enterprises of all sizes, whether commercial, not-for-profit or in the public sector.

COBIT 5 Principles



Source: COBIT® 5, figure 2. © 2012 ISACA® All rights reserved.

Meeting Stakeholder Needs

Principle 1. Meeting Stakeholder Needs:

- Enterprises have **many** stakeholders, and 'creating value' means different—and sometimes conflicting—things to each of them.
- Governance is about negotiating and deciding amongst different stakeholders' value interests.
- The governance system should consider all stakeholders when making benefit, resource and risk assessment decisions.
- For each decision, the following can and should be asked:
  - Who receives the benefits?
  - Who bears the risk?
  - What resources are required?

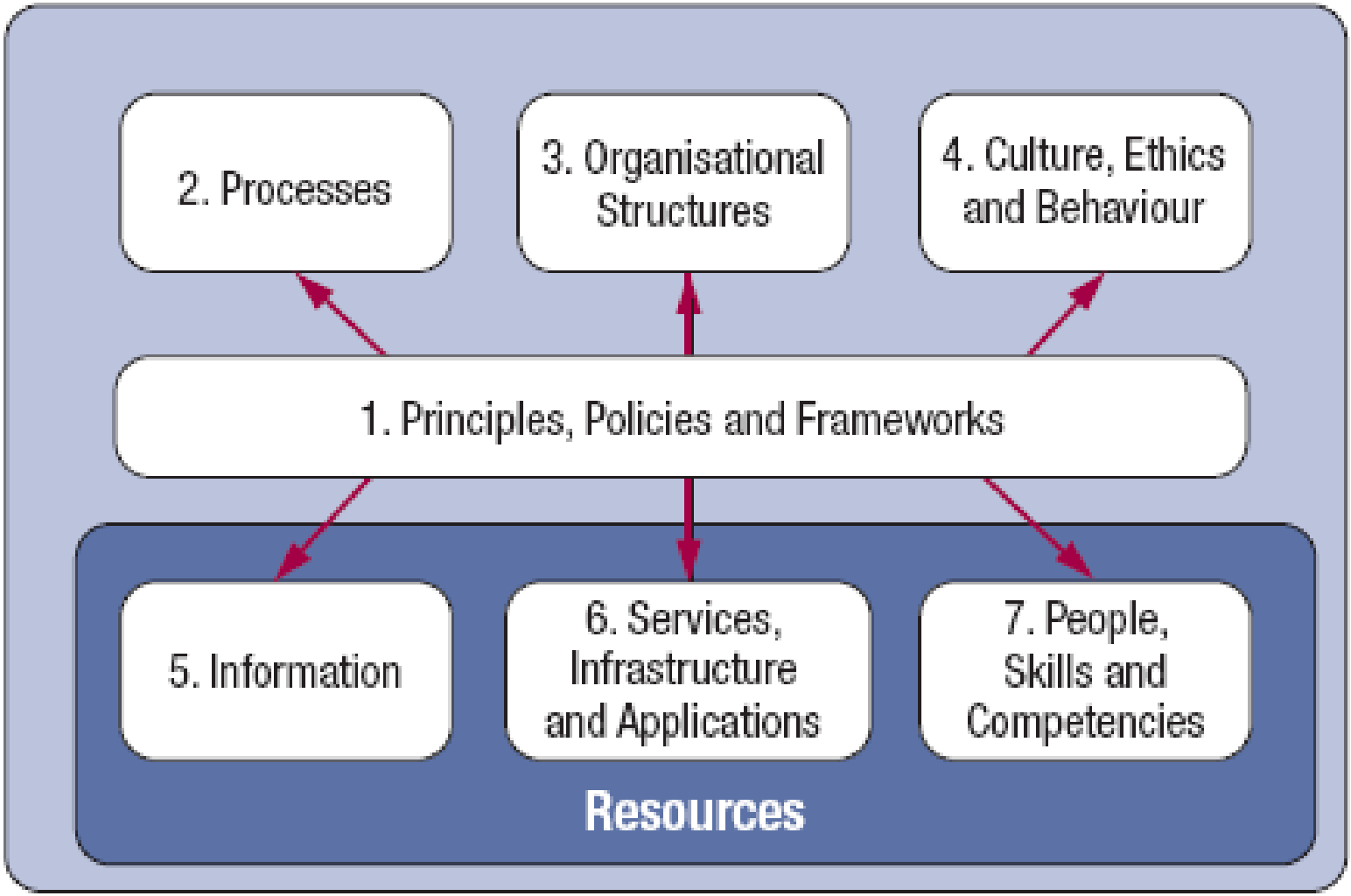
1. Meeting Stakeholder Needs



- Stakeholder needs transformed into an actionable enterprise strategy.
- The COBIT 5 '**goals cascade**' translates stakeholder needs into specific, practical and customised goals within the context of the enterprise, IT-related goals and enabler goals.

Source: COBIT® 5, figure 4. © 2012 ISACA® All rights reserved.

COBIT 5 Enablers



Source: COBIT® 5, figure 12. © 2012 ISACA® All rights reserved.

QUESTIONS ?




Thank
You